

CVE-2026-41089 Windows Netlogon RCE

CVE-2026-41089 Windows Netlogon RCE

Vulnerability Threat Intelligence Report

Field	Value
Classification	TLP:CLEAR
Published	2026-06-03
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-41089 Windows Netlogon RCE - Vulnerability Report

Published: 2026-06-03 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

1. Executive Summary

CVE-2026-41089 is a critical remote code execution vulnerability in Windows Netlogon. Microsoft describes it as a stack-based buffer overflow that allows an unauthorized attacker to execute code over a network. The vulnerability carries a CVSS v3.1 base score of 9.8 with network attack vector, low attack complexity, no privileges required, and no user interaction required.

This vulnerability is especially dangerous because Netlogon is central to Active Directory domain authentication and domain-controller trust operations. Microsoft states that an attacker could send a specially crafted network request to a Windows server acting as a domain controller and, if successful, cause Netlogon to mishandle the request and potentially run attacker-controlled code without prior access. Successful exploitation of a domain controller should be treated as a potential domain or forest compromise event.

Microsoft released fixes on 2026-05-12 as part of the May 2026 security update cycle. At publication time Microsoft marked the vulnerability as not publicly disclosed, not exploited, and “Exploitation Less Likely”; however, later public reporting cites the Centre for Cybersecurity Belgium warning that exploitation has been observed in the wild. CISA KEV did not list CVE-2026-41089 at the time this report queried the KEV feed on 2026-06-03.

Confirmed facts:

- CVE ID: **CVE-2026-41089**.
- Vendor: Microsoft.
- Component: Windows Netlogon.
- Impact: Remote Code Execution.
- CWE: **CWE-121: Stack-based Buffer Overflow**.
- CVSS v3.1: **9.8 Critical**.
- CVSS vector: **CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H**.
- Microsoft release date: 2026-05-12.
- Affected products include Windows Server 2012, 2012 R2, 2016, 2019, 2022, Windows Server 2022 23H2, and Windows Server 2025, including Server Core variants where applicable.
- Remediation requires installing the Microsoft security updates for affected systems; Microsoft marks customer action required and reboot required.

Analyst assessment:

- Treat this as an emergency domain-controller patch and monitoring item.
- Prioritize all domain controllers first, then domain-joined Windows servers that expose Netlogon/RPC surfaces.
- If exploitation is suspected, assume SYSTEM-level code execution on a domain controller is possible and begin AD-compromise response, not ordinary host triage.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-41089
Title	Windows Netlogon Remote Code Execution Vulnerability
Vendor / CNA	Microsoft
Published	2026-05-12
NVD last modified	2026-05-15
Release train	Microsoft 2026-May
Component	Windows Netlogon / Netlogon Remote Protocol
Vulnerability class	Stack-based buffer overflow
CWE	CWE-121
Impact	Remote Code Execution
CVSS v3.1 base score	9.8 Critical
CVSS vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Attack vector	Network

Field	Value
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality / Integrity / Availability	High / High / High
Microsoft exploitability at release	Exploitation Less Likely
Microsoft exploited field at release/API query	No
Public exploitation reporting	Public reporting cites CCB active-exploitation warning
CISA KEV status at query time	Not found in KEV feed on 2026-06-03

3. Source Review & Confidence

Claim	Source	Source Date	Confidence	Notes
CVE-2026-41089 is a Windows Netlogon RCE caused by a stack-based buffer overflow.	Microsoft MSRC API and NVD	2026-05-12 / 2026-05-15	High	Vendor and NVD agree on description and CWE.
The CVSS v3.1 score is 9.8 Critical with network, low complexity, no privileges, and no user interaction.	Microsoft MSRC API and NVD	2026-05-12 / 2026-05-15	High	Microsoft is the CNA source.
Microsoft's FAQ says exploitation involves a specially crafted network request to a Windows server acting as a domain controller.	Microsoft MSRC API	2026-05-12	High	Vendor-provided FAQ text.
Affected product set spans Windows Server 2012 through Windows Server 2025, including Server Core variants.	Microsoft affectedProduct API and NVD configurations	2026-05-12 / 2026-05-15	High	Structured affected-product and CPE data.
Public reporting says CCB warned of active exploitation.	Help Net Security citing Centre for Cybersecurity Belgium	2026-06-01	Medium	CCB warning was not directly retrievable from official CCB site during this run; treat as credible but separately sourced.

Claim	Source	Source Date	Confidence	Notes
CISA KEV did not list CVE-2026-41089 when queried.	CISA KEV JSON feed	2026-06-03	High	Direct feed query returned no matching CVE.
No public exploit details should be required for defensive prioritization.	Analyst assessment based on CVSS and domain-controller blast radius	2026-06-03	High	Severity is sufficient for emergency patching.

Source limitations:

- Microsoft's web advisory requires JavaScript, so this report used the public MSRC API for structured vendor data.
- CCB's underlying public warning could not be directly retrieved from an official CCB advisory page in this run; active exploitation is therefore cited through Help Net Security and tracked separately from MSRC/CISA status.
- No proof-of-concept exploit was downloaded, run, or reproduced.

4. Vulnerability Details

CVE-2026-41089 is a stack-based buffer overflow in Windows Netlogon. Netlogon is a core Windows domain service used for secure channel operations, domain authentication support, and domain-controller trust relationships.

Microsoft's FAQ describes the exploit path at a high level: an attacker sends a specially crafted network request to a Windows server acting as a domain controller. If exploitation succeeds, the Netlogon service may improperly handle the request and allow code execution on the affected system without sign-in or prior access.

Technical significance:

- The vulnerability is pre-authentication from the perspective of the Microsoft scoring: **PR:N**.
- It does not require user interaction: **UI:N**.
- The attack vector is network reachable: **AV:N**.
- Domain controllers are the highest-risk asset class because code execution on a DC can expose Active Directory secrets, Kerberos material, replication data, and administrative control paths.
- Netlogon failures may also produce availability impact, including service crash, domain authentication disruption, or domain trust errors.

Likely target surface:

- Domain controllers.
- Windows Server systems acting in domain-controller roles.
- Domain-joined Windows servers exposing Netlogon RPC paths to untrusted or semi-trusted networks.
- Flat internal networks where workstation, server, or VPN segments can reach DC RPC/SMB services directly.

5. Attack Scenarios

5.1 External-To-Internal Pivot Against Exposed DC

If a domain controller or Netlogon/RPC service is reachable from an untrusted network, an attacker could send crafted network traffic directly at the DC. Domain controllers should not expose Netlogon/RPC broadly to the internet, but accidental exposure through firewall rules, VPN misconfiguration, or cloud network peering can create direct risk.

Likely impact:

- Netlogon crash or service instability.
- SYSTEM-level code execution on the DC if exploitation succeeds.
- Rapid credential theft, domain persistence, and AD-wide compromise.

5.2 Post-Perimeter Exploitation From Compromised Internal Host

The more realistic enterprise scenario is an attacker already inside the network from VPN compromise, phishing, exposed RMM, or compromised workstation. From there, the attacker scans for domain controllers and targets Netlogon/RPC interfaces.

Likely impact:

- Privilege escalation from initial foothold to domain-control position.
- Kerberos abuse, DCSync, credential dumping, GPO modification, and lateral movement.
- Ransomware pre-positioning or destructive operations.

5.3 Denial-of-Service / Authentication Disruption

Even unsuccessful exploitation may crash or destabilize Netlogon. On a domain controller, Netlogon instability can create authentication failures, machine secure-channel problems, and domain trust errors.

Likely impact:

- Authentication outages.
- Application failures caused by domain auth dependencies.
- SOC noise from service restarts and repeated authentication errors.

6. Threat Landscape & Exploitation Status

Microsoft release-time status:

- Publicly disclosed: No.
- Exploited: No.
- Exploitability assessment: Exploitation Less Likely.
- Customer action required: Yes.

Public field reporting:

- Help Net Security reported on 2026-06-01 that the Centre for Cybersecurity Belgium warned of active exploitation in the wild.
- The same reporting notes that CCB had not publicly shared detailed attack telemetry at that time.
- Several secondary outlets repeated the CCB exploitation warning, but most trace back to the same public signal.

CISA KEV:

- This report queried the CISA Known Exploited Vulnerabilities JSON feed on 2026-06-03.
- CVE-2026-41089 was not present in the KEV feed at query time.

Analyst assessment:

- The gap between vendor release-time exploitability assessment and later exploitation reporting should not delay remediation.
- A pre-authentication RCE against domain controllers is high-consequence even with limited public exploit details.
- If CCB reporting is accurate, defenders should assume opportunistic scanning and targeted exploitation may increase quickly as patch-diffing and proof-of-concept work matures.

7. Affected Products and Exposure

7.1 Affected Microsoft Products and Fixes

Product	Fixed KB	Fixed Build	Reboot
Windows Server 2012	KB5087470	6.2.9200.26079	Yes
Windows Server 2012 (Server Core installation)	KB5087470	6.2.9200.26079	Yes
Windows Server 2012 R2	KB5087471	6.3.9600.23181	Yes

Product	Fixed KB	Fixed Build	Reboot
Windows Server 2012 R2 (Server Core installation)	KB5087471	6.3.9600.23181	Yes
Windows Server 2016	KB5087537	10.0.14393.9140	Yes
Windows Server 2016 (Server Core installation)	KB5087537	10.0.14393.9140	Yes
Windows Server 2019	KB5087538	10.0.17763.8755	Yes
Windows Server 2019 (Server Core installation)	KB5087538	10.0.17763.8755	Yes
Windows Server 2022	KB5087545 / KB5087424 hotpatch	10.0.20348.5139 / 10.0.20348.5074	Yes
Windows Server 2022 (Server Core installation)	KB5087545 / KB5087424 hotpatch	10.0.20348.5139 / 10.0.20348.5074	Yes
Windows Server 2022, 23H2 Edition (Server Core installation)	KB5087541	10.0.25398.2330	Yes
Windows Server 2025	KB5087539 / KB5087423 hotpatch	10.0.26100.32860 / 10.0.26100.32772	Yes
Windows Server 2025 (Server Core installation)	KB5087539 / KB5087423 hotpatch	10.0.26100.32860 / 10.0.26100.32772	Yes

7.2 Exposure Review

Priority assets:

- All writable domain controllers.
- Read-only domain controllers in branch networks.
- Domain controllers in disaster-recovery or cloud landing zones.
- Domain controllers reachable from VPN pools, VDI networks, server-management networks, or partner links.
- Legacy Server 2012 / 2012 R2 systems still under ESU.

Network services to review:

- RPC endpoint mapper on TCP 135.
- SMB / named pipe access on TCP 445, including \PIPE\NETLOGON.
- Dynamic RPC ranges used by domain controllers.
- Any segmentation exceptions that allow broad client-to-DC RPC traffic beyond what business workflows require.

8. Mitigation and Workarounds

Primary remediation:

- Install the Microsoft May 2026 security updates for all affected Windows Server versions.
- Patch all domain controllers in a coordinated emergency maintenance window.
- Reboot as required and verify fixed build numbers.

Operational guidance:

- Do not leave “half-patched” domain-controller forests. Patch domain controllers consistently to avoid leaving exploitable DCs behind.
- Prioritize external exposure elimination before routine scheduling if any DC RPC/SMB surface is reachable from untrusted networks.
- Verify backups and system-state recovery before patching, but do not allow backup process delays to defer emergency remediation indefinitely.

Network risk reduction:

- Restrict inbound Netlogon/RPC/SMB access to domain controllers to only required networks and hosts.

- Block internet-originated access to TCP 135, TCP 445, and dynamic RPC ranges on DCs.
- Review VPN and workstation VLAN rules; do not assume “internal” equals trusted.
- Monitor and rate-limit anomalous RPC traffic to DCs where tooling supports it.

Compensating controls:

- Enable and centralize Windows Event logs from all DCs.
- Ensure Sysmon or EDR coverage on DCs where operationally approved.
- Enable Netlogon debug logging temporarily during investigation if needed, understanding log-volume impact.
- Monitor service-control, process-creation, LSASS access, DCSync, and domain-admin group changes.

No reliable workaround replaces patching for this vulnerability. Network filtering can reduce exposure but may disrupt legitimate domain operations if applied without testing.

9. Detection Engineering

9.1 Detection Hypotheses

Hypothesis	Data Source	Expected Artifact
If exploitation attempts crash or destabilize Netlogon, DC System logs will show Netlogon or service-control failures.	Windows System Event Log	Service Control Manager 7031/7034, Netlogon events, unexpected service restarts.
If exploitation traffic is sent from non-DC clients, network telemetry will show anomalous RPC/SMB traffic to domain controllers.	Firewall, Zeek, NetFlow, NDR	TCP 135/445 or dynamic RPC from unusual source hosts to DCs.
If exploitation succeeds, the DC may spawn unusual child processes or post-exploitation tooling under SYSTEM.	EDR/Sysmon	Suspicious process creation, command shells, credential dumping, PowerShell, new services.
If attackers escalate to AD compromise, directory audit logs may show privileged group changes, DCSync, replication abuse, or GPO changes.	Security Event Log, Directory Service logs, EDR	4662 replication access, 4728/4732/4756 group membership changes, GPO edits.

9.2 Sigma - Netlogon Service Crash or Restart on Domain Controller

```

title: Netlogon Service Crash Or Restart On Domain Controller
id: e4e58c1f-4108-4e89-8b6b-netlogon-rce-watch
status: experimental
description: Detects unexpected Netlogon service failures or restarts on domain controllers, which may indicate exploitation attempts
↳ or instability related to CVE-2026-41089.
author: Lost Boys Cyber
date: 2026-06-03
references:
- https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-41089
- https://nvd.nist.gov/vuln/detail/CVE-2026-41089
tags:
- attack.impact
- attack.t1499
- attack.execution
logsource:
  product: windows
  service: system
detection:
  selection_service_control:
    EventID:
    - 7031

```



```

- 7034
selection_netlogon:
  Provider_Name: Service Control Manager
  Message|contains: Netlogon
  condition: selection_service_control and selection_netlogon
falsepositives:
  - Planned domain controller maintenance
  - Service restart during patching
  - Known Netlogon operational issues unrelated to exploitation
level: high

```

9.3 Sigma - Suspicious Process Spawned From Netlogon Context

```

title: Suspicious Process Spawned On Domain Controller After Netlogon Activity
id: 41089f5e-9d6d-41c2-8a1f-netlogon-post-exploitation
status: experimental
description: Detects suspicious command or scripting processes on domain controllers that may follow successful Netlogon RCE
↳ exploitation.
author: Lost Boys Cyber
date: 2026-06-03
references:
  - https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-41089
tags:
  - attack.execution
  - attack.t1059
  - attack.credential_access
logsource:
  product: windows
  category: process_creation
detection:
  selection_dc_process:
    Image|endswith:
      - '\cmd.exe'
      - '\powershell.exe'
      - '\pwsh.exe'
      - '\wscript.exe'
      - '\cscript.exe'
      - '\rundll32.exe'
      - '\regsvr32.exe'
      - '\certutil.exe'
      - '\bitsadmin.exe'
  selection_context:
    IntegrityLevel:
      - System
      - High
    condition: selection_dc_process and selection_context
falsepositives:
  - Administrative scripts on domain controllers
  - Backup or monitoring agents
  - Patch orchestration
level: medium

```

9.4 Microsoft Defender KQL - DC Service Failures and Suspicious Processes

```

let DomainControllers = dynamic(["DC01", "DC02", "DC03"]);
let suspicious = dynamic(["cmd.exe", "powershell.exe", "pwsh.exe", "wscript.exe", "cscript.exe", "rundll32.exe", "regsvr32.exe",
↳ "certutil.exe", "bitsadmin.exe"]);
DeviceProcessEvents
| where Timestamp > ago(14d)
| where DeviceName in~ (DomainControllers)
| where FileName in~ (suspicious)
| where InitiatingProcessAccountSid == "S-1-5-18" or ProcessIntegrityLevel in~ ("System", "High")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine, AccountName,
↳ ReportId
| order by Timestamp desc

```

9.5 Microsoft Sentinel KQL - Netlogon / Service Control Events

```
let DomainControllers = dynamic(["DC01", "DC02", "DC03"]);
Event
| where TimeGenerated > ago(14d)
| where Computer in~ (DomainControllers)
| where EventLog == "System"
| where EventID in (5719, 5722, 5805, 5807, 7031, 7034)
| where RenderedDescription has_any ("Netlogon", "NETLOGON", "The Netlogon service", "trust relationship", "session setup")
| project TimeGenerated, Computer, EventID, Source, RenderedDescription
| order by TimeGenerated desc
```

9.6 Network Detection Logic

Detection goals:

- Identify unusual hosts initiating RPC/SMB sessions to DCs.
- Identify spikes in failed or reset connections to DC RPC/SMB services.
- Identify non-domain-controller source addresses repeatedly contacting Netlogon-related services.

Telemetry:

- Zeek conn.log, dce_rpc.log, and smb_mapping.log.
- Firewall logs.
- NDR RPC protocol metadata.
- Windows Filtering Platform logs where enabled.

Example Zeek-style logic:

```
Alert when:
- destination host is a domain controller
- destination port is 135, 445, or known dynamic RPC range
- source host is not in approved admin, server, or domain-controller lists
- connection count exceeds baseline or is followed by DC Netlogon service errors
```

Validation:

- Baseline domain join, password change, trust, backup, monitoring, and admin workflows.
- Tune out known server-management systems and DC-to-DC replication paths.
- Keep detection higher severity when service crashes or suspicious process creation occur within 10 minutes of anomalous network traffic.

10. Threat Hunting

Hunt 1 - Identify Unpatched Domain Controllers

Hypothesis:

- Any DC below the fixed build or missing the May 2026 KB remains vulnerable.

KQL hunt query:

```
let FixedBuilds = datatable(OS:string, FixedBuild:string)
[
  "Windows Server 2016", "10.0.14393.9140",
  "Windows Server 2019", "10.0.17763.8755",
  "Windows Server 2022", "10.0.20348.5074",
  "Windows Server 2022 23H2", "10.0.25398.2330",
  "Windows Server 2025", "10.0.26100.32772"
];
DeviceInfo
| where Timestamp > ago(7d)
| summarize arg_max(Timestamp, *) by DeviceName
| where DeviceName startswith "DC" or DeviceType == "Domain Controller" or OSPlatform has "WindowsServer"
| project Timestamp, DeviceName, OSPlatform, OSVersion, PublicIP, ExposureLevel, OnboardingStatus
| order by OSPlatform asc, OSVersion asc
```

PowerShell validation query:

```
Get-ADDomainController -Filter * |
  Select-Object HostName,Site,IPv4Address,OperatingSystem,OperatingSystemVersion |
  Sort-Object OperatingSystemVersion
```

Patch verification query:

```
$kbs = 'KB5087470','KB5087471','KB5087537','KB5087538','KB5087545','KB5087424','KB5087541','KB5087539','KB5087423'
Get-ADDomainController -Filter * | ForEach-Object {
  $dc = $_.HostName
  Get-HotFix -ComputerName $dc -ErrorAction SilentlyContinue |
    Where-Object HotFixID -in $kbs |
    Select-Object @{n='ComputerName';e={$dc}},HotFixID,InstalledOn
}
```

Triage:

- Prioritize any domain controller missing its fixed KB or fixed build.
- Reboot and confirm build after update installation.
- For Server 2012 / 2012 R2, confirm ESU entitlement and patch applicability.

Hunt 2 - Netlogon Service Instability on DCs

Hypothesis:

- Exploitation attempts or malformed probing may crash or restart Netlogon.

KQL hunt query:

```
let DomainControllers = dynamic(["DC01", "DC02", "DC03"]);
Event
| where TimeGenerated > ago(30d)
| where Computer in~ (DomainControllers)
| where EventLog == "System"
| where EventID in (5719, 5722, 5805, 5807, 7031, 7034)
| where RenderedDescription has_any ("Netlogon", "NETLOGON", "trust relationship", "session setup", "service terminated unexpectedly")
| summarize Count=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated), EventIDs=make_set(EventID),
  ↳ Examples=make_set(RenderedDescription, 3) by Computer
| order by Count desc
```

Splunk SPL:

```
index=wineventlog sourcetype="WinEventLog:System" earliest=-30d
(EventCode=5719 OR EventCode=5722 OR EventCode=5805 OR EventCode=5807 OR EventCode=7031 OR EventCode=7034)
("Netlogon" OR "NETLOGON" OR "trust relationship" OR "session setup" OR "service terminated unexpectedly")
| stats count min(_time) as first_seen max(_time) as last_seen values(EventCode) as event_codes values(Message) as sample_messages by
  ↳ host
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

Triage:

- Review patching timestamps to separate maintenance from suspicious instability.
- Correlate event time with network traffic to TCP 135/445 and dynamic RPC.
- If unexplained, isolate the DC from nonessential inbound traffic and begin compromise assessment.

Hunt 3 - Anomalous RPC/SMB Traffic to Domain Controllers

Hypothesis:

- Exploitation attempts require network reachability to domain-controller RPC/SMB surfaces.

KQL hunt query for Defender network events:

```
let DomainControllers = dynamic(["DC01.contoso.local", "DC02.contoso.local"]);
let AllowedSources = dynamic(["MGMT01", "MONITOR01", "BACKUP01"]);
```

```
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemotePort in (135, 445) or RemotePort between (49152 .. 65535)
| where RemoteUrl in~ (DomainControllers) or RemoteDeviceName in~ (DomainControllers)
| where not(DeviceName in~ (AllowedSources))
| summarize Count=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Ports=make_set(RemotePort),
  ↳ InitiatingProcesses=make_set(InitiatingProcessFileName, 10) by DeviceName, RemoteDeviceName, RemoteUrl, RemoteIP
| where Count > 25
| order by Count desc
```

Zeek/Splunk SPL:

```
index=zeek earliest=-14d (id.resp_p=135 OR id.resp_p=445 OR (id.resp_p>=49152 AND id.resp_p<=65535))
dest_category=domain_controller NOT src_category IN ("domain_controller","management","backup","monitoring")
| stats count min(_time) as first_seen max(_time) as last_seen values(id.resp_p) as ports by id.orig_h id.resp_h
| where count > 25
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

Triage:

- Determine whether source host is expected to perform domain administration.
- If source is a workstation or VPN client, investigate for scanning or initial compromise.
- Correlate with DC service instability and process creation.

Hunt 4 - Post-Exploitation Activity on Domain Controllers

Hypothesis:

- Successful exploitation may be followed by command execution, credential access, service creation, or AD changes.

KQL hunt query:

```
let DomainControllers = dynamic(["DC01", "DC02", "DC03"]);
let SuspiciousProcesses = dynamic(["cmd.exe", "powershell.exe", "pwsh.exe", "rundll32.exe", "regsvr32.exe", "certutil.exe",
  ↳ "bitsadmin.exe", "wmic.exe", "nltest.exe", "ntdsutil.exe", "vssadmin.exe"]);
DeviceProcessEvents
| where Timestamp > ago(14d)
| where DeviceName in~ (DomainControllers)
| where FileName in~ (SuspiciousProcesses)
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine,
  ↳ ReportId
| order by Timestamp desc
```

Windows event KQL for privileged changes:

```
let DomainControllers = dynamic(["DC01", "DC02", "DC03"]);
SecurityEvent
| where TimeGenerated > ago(14d)
| where Computer in~ (DomainControllers)
| where EventID in (4720, 4728, 4732, 4756, 4739, 4670, 4662, 7045)
| project TimeGenerated, Computer, EventID, Account, TargetAccount, Activity, EventData
| order by TimeGenerated desc
```

Splunk SPL:

```
index=wineventlog earliest=-14d host IN ("DC01","DC02","DC03")
(
  sourcetype="WinEventLog:Security" AND (EventCode=4720 OR EventCode=4728 OR EventCode=4732 OR EventCode=4756 OR EventCode=4662 OR
  ↳ EventCode=7045)
)
OR
(
  sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" AND EventCode=1 AND
  (Image="*\\cmd.exe" OR Image="*\\powershell.exe" OR Image="*\\ntdsutil.exe" OR Image="*\\vssadmin.exe")
)
```

	table	_time	host	EventCode	Account_Name	Target_Account_Name	Image	CommandLine	ParentImage	ParentCommandLine	Message
--	-------	-------	------	-----------	--------------	---------------------	-------	-------------	-------------	-------------------	---------

Triage:

- Look for LSASS access, `ntds.dit` staging, volume shadow copy creation, DCSync rights use, new services, or new privileged users.
- If suspicious activity is confirmed, move directly to AD compromise containment.

11. MITRE ATT&CK Mapping

Technique	Name	Applicability	Evidence / Rationale
T1190	Exploit Public-Facing Application	Medium	Applies if Netlogon/RPC is exposed beyond trusted internal networks.
T1210	Exploitation of Remote Services	High	Core exploitation path is remote service exploitation over the network.
T1068	Exploitation for Privilege Escalation	Medium	If attacker has internal foothold, exploitation may elevate to SYSTEM on DC.
T1059	Command and Scripting Interpreter	Medium	Expected post-exploitation behavior after RCE.
T1003.003	OS Credential Dumping: NTDS	High	Likely post-compromise objective on DCs.
T1003.001	OS Credential Dumping: LSASS Memory	High	Common post-compromise objective on Windows servers.
T1482	Domain Trust Discovery	Medium	Attackers may enumerate trust relationships after DC compromise.
T1087.002	Account Discovery: Domain Account	Medium	Expected after AD foothold.
T1098	Account Manipulation	High	Attackers may create privileged accounts or alter group memberships.
T1484.001	Domain Policy Modification: Group Policy Modification	Medium	Possible domain persistence and lateral movement path.
T1499	Endpoint Denial of Service	Medium	Netlogon crashes or domain authentication failures may cause availability impact.

12. Validation / Lab Testing

Safe validation steps:

- Confirm all domain controllers and affected servers have the correct KB or fixed build.
- Validate event collection from DC System, Security, Directory Service, and Sysmon/EDR logs.
- Test detection content with benign service-restart simulations only during maintenance windows.
- Use a lab domain to validate log collection and query behavior; do not run public exploit code in production.

Recommended validation checklist:

1. Run `Get-ADDomainController -Filter *` and inventory OS versions.
2. Run `Get-HotFix` checks for relevant KBs.
3. Confirm DC fixed build numbers match or exceed the MSRC affected-product table.
4. Confirm Event ID 7031/7034 service failures reach SIEM.
5. Confirm process telemetry from DCs reaches EDR/SIEM.
6. Confirm firewall/NDR visibility for TCP 135/445 and dynamic RPC to DCs.
7. Run tabletop exercise for “RCE on domain controller” response.

Do not validate by sending malformed Netlogon requests to production domain controllers.

13. Recommended Actions Summary

Priority	Owner	Timeline	Action
Critical	AD / Infrastructure	24 hours	Patch every domain controller with the applicable Microsoft May 2026 update and reboot.
Critical	AD / Infrastructure	24 hours	Verify fixed builds and produce an exception list for any unpatched DC.
Critical	Network Security	24 hours	Confirm DC RPC/SMB/Netlogon surfaces are not reachable from the internet, guest networks, or broad VPN pools.
High	SOC	24-48 hours	Deploy hunts for Netlogon service instability, anomalous RPC/SMB to DCs, and suspicious DC process creation.
High	IR	24-48 hours	Prepare a domain-controller compromise playbook, including KRBTGT reset planning, privileged credential rotation, and tier-0 isolation.
High	Identity / AD	72 hours	Review domain-admin and privileged group changes since 2026-05-12.
Medium	Vulnerability Management	1 week	Validate patch coverage for Server 2012 / 2012 R2 ESU systems and Server Core variants.
Medium	Security Engineering	1 week	Add DC network segmentation baselines and exception review for TCP 135/445/dynamic RPC.
Medium	GRC	2 weeks	Document risk acceptance for any DC that cannot be patched immediately and require compensating controls.

If exploitation is suspected:

- Isolate the affected DC from nonessential network access while preserving evidence.
- Do not immediately power off unless containment requires it; preserve volatile evidence where possible.
- Assume tier-0 compromise until disproven.
- Rotate privileged credentials and plan KRBTGT reset if AD compromise indicators are confirmed.
- Review DCSync, `ntds.dit` access, shadow copy creation, new services, GPO changes, and privileged group membership changes.

14. References

- Microsoft MSRC API, “CVE-2026-41089 Windows Netlogon Remote Code Execution Vulnerability.” <https://api.msrmicrosoft.com/sug/v2.0/en-US/vulnerability/CVE-2026-41089>
- Microsoft MSRC Security Update Guide. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-41089>
- Microsoft MSRC affectedProduct API for CVE-2026-41089. <https://api.msrmicrosoft.com/sug/v2.0/en-US/affectedProduct?filter=cveNumber%20eq%20CVE-2026-41089%27>
- NVD, “CVE-2026-41089 Detail.” <https://nvd.nist.gov/vuln/detail/CVE-2026-41089>
- CISA Known Exploited Vulnerabilities Catalog JSON feed, queried 2026-06-03. <https://www.cisa.gov/sites/default/files/>
- Help Net Security, “Windows Netlogon RCE exploited, domain controllers at risk (CVE-2026-41089),” 2026-06-01. <https://www.helpnetsecurity.com/2026/06/01/windows-netlogon-rce-exploited-cve-2026-41089/>
- MITRE ATT&CK, T1210 “Exploitation of Remote Services.” <https://attack.mitre.org/techniques/T1210/>
- MITRE ATT&CK, T1003.003 “OS Credential Dumping: NTDS.” <https://attack.mitre.org/techniques/T1003/003/>
- MITRE CWE, CWE-121 “Stack-based Buffer Overflow.” <https://cwe.mitre.org/data/definitions/121.html>

Refresh notes:

- Re-check MSRC for revisions, known issues, and replacement KBs before executive distribution.
- Re-check CISA KEV because the status may change quickly if exploitation reporting is confirmed by U.S. authorities.
- Replace placeholder DC names in KQL/SPL queries with local domain-controller inventory before deployment.